

IT & Information Security Policy

Document Ref: IT-POL-007 | Effective: July 2026

As a technology-driven organization, safeguarding TechV-Flash's intellectual property, client data, and internal systems is paramount. This policy applies to all employees, contractors, and interns using company-provisioned IT assets or accessing company networks.

1. Password & Authentication Protocols

1.1 Password Complexity Rules

All system passwords must be at least 14 characters long, containing a mix of uppercase, lowercase, numbers, and special characters. Passwords must not contain personal details (e.g., names, birthdays).

1.2 Mandatory Rotation & History

Passwords must be updated every 90 days. The system will restrict users from reusing any of their last 5 previous passwords.

1.3 Multi-Factor Authentication (MFA)

MFA is strictly enforced across all TechV-Flash applications (Google Workspace, AWS, GitHub, HR Portal). Authenticator apps (e.g., Google Authenticator, Authy) are permitted. SMS-based OTPs are prohibited due to SIM-swapping vulnerabilities.

2. Hardware & Device Management

2.1 Asset Allocation

Employees are strictly forbidden from sharing their company-issued laptops, phones, or security keys with anyone, including family members. Hardware remains the sole property of TechV-Flash.

2.2 BYOD (Bring Your Own Device) Limitations

Personal devices may only be used to access company email and Microsoft Teams, provided Mobile Device Management (MDM) software is installed. Source code and client databases must never be downloaded to personal devices.

Incident Reporting Timeline: Any loss, theft, or suspected compromise of a TechV-Flash device must be reported to the IT Helpdesk (it-sec@techv-flash.com) within 2 hours of discovery. Failure to report promptly will result in disciplinary action.

3. Network Security & VPN

3.1 VPN Mandate for Remote Work

When working remotely (as per HR-POL-003), employees must be connected to the TechV-Flash corporate VPN at all times before accessing internal servers, staging environments, or client data.

3.2 Public Wi-Fi Restrictions

Accessing company resources over unsecured public Wi-Fi networks (e.g., airports, coffee shops) without the VPN is classified as a critical security violation.

4. Data Classification

All data processed by TechV-Flash is categorized into four tiers. Handling requirements depend on the tier:

Classification	Description	Examples	Sharing Rules
Public	Information meant for general consumption.	Marketing materials, Press releases	No restrictions.
Internal Use	Company operations info, not for external release.	Organizational charts, Intranet pages	Share only with TechV-Flash staff.
Confidential	Sensitive business data requiring protection.	Financial reports, Source code, Vendor contracts	Need-to-know basis internally; NDA required externally.
Restricted	Highly sensitive PII or client data subject to regulations.	Employee passwords, Client databases, PHI	Strictly limited to authorized personnel only. Encryption mandatory.

5. Software Installation & "Shadow IT"

5.1 Administrator Privileges

Standard employee accounts do not possess local administrative rights. Software installations must be requested via the IT Service Portal.

5.2 Prohibition of Unauthorized Tools

The use of unapproved third-party applications or SaaS tools ("Shadow IT") for company business is strictly forbidden. This includes unauthorized Generative AI tools where confidential code might be pasted.

6. Remote Work Infrastructure & Physical Security

6.1 Clean Desk and Workstation Security

When working in open offices or remote spaces, employees must lock their screens (`Win + L` or `Cmd + Ctrl + Q`) before leaving the workstation. Hard copies containing confidential data must be filed in lockable drawers.

6.2 Home Office Security Standards

Remote workers must ensure that smart home assistant devices (e.g., Alexa, Google Home) are disabled or muted in rooms where confidential work discussions are conducted.

7. Social Engineering & Phishing Prevention

7.1 Security Training Obligation

All employees must participate in quarterly cybersecurity awareness and social engineering training. Critical modules cover spoofed emails, social engineering calls, and identity validation.

7.2 Simulated Phishing Exercises

IT Security conducts unannounced simulated phishing tests. Repeated failure (clicking malicious links, inputting credentials in tests) triggers mandatory review and administrative actions.

7.3 Table of Phishing Drill Consequences

Fail Cycle Frequency	Immediate Consequence	Required Remediation	HR File Status
First Failure	Notification from Security Team	Online micro-learning course (15 mins)	No Entry
Second Failure (within 12 months)	Manager Notified	Assigned Security Bootcamp (1 hour)	Logged as Warning
Third Failure (within 12 months)	Local Admin privileges revoked	In-person Security Interview with DPO	Written Disciplinary Record

8. Cryptographic Standards & Data Transfer

8.1 Symmetric Encryption

Restricted database files and corporate backup bundles must be encrypted using AES-256 standard before transfer or storage on third-party cloud containers.

8.2 Shared Transmission Channels

Confidential and Restricted data must only be transmitted through approved company channels (e.g., authenticated SFTP servers, OneDrive with link validation). Email attachments for Restricted documents are prohibited.

8.3 Table of Approved File Transfer & Cryptographic Tools

Data Tier Category	Approved File Transfer Tool	Minimum Encryption Protocol	Authorization Required
Internal Use	Google Drive (Standard sharing)	TLS 1.2 in transit	None (All staff accessible)
Confidential	OneDrive (Password-protected link)	AES-256 at rest & TLS 1.3	Manager Approval
Restricted	Secure SFTP Server / AWS S3 KMS	AES-256 with KMS key controls	Security Officer sign-off

9. Vulnerability Management & Access Reviews

9.1 Device Patching Schedule

All endpoint devices must keep auto-updates active. Critical security patches pushed by the corporate Mobile Device Management (MDM) software must be installed within 48 hours of publication.

9.2 Access Audits

Department heads must conduct access audits quarterly to review employee privileges on repository codes, AWS roles, and customer databases, following the principle of Least Privilege.

10. Incident Response & Disaster Recovery

10.1 Incident Triage Matrix

Cybersecurity incidents are classified into severity levels by the Incident Response (IR) team. SLAs for resolution and customer notification depend on these classes.

10.2 Table of Incident Severity Levels & SLAs

Severity Class	Definition / Impact Area	Incident Response SLA	Resolution Target SLA
Severity 1 (Critical)	Active data breach, root credentials compromised, customer database leaked.	Immediate (Within 15 minutes)	Under 6 Hours
Severity 2 (High)	Individual system compromise, phishing email click with credentials entered.	Within 1 Hour	Under 24 Hours
Severity 3 (Medium/Low)	Loss of offline laptop with active BitLocker, policy bypass without data access.	Within 4 Hours	Under 72 Hours

11. Termination & Asset Deprovisioning

11.1 Privilege Deactivation Timeline

Upon notification of resignation or termination, IT Security schedules privilege deactivation. On the last working day at the exit time, all company application access (Google, Slack, GitHub) will be deactivated immediately.

11.2 Asset Reclamation & Wipe

Returned laptops are held in quarantine for 15 days for legal review if required. Subsequently, the device storage undergoes a secure multi-pass data wipe compliant with DoD 5220.22-M standards before reissue.